Lab implementation guide: five phases

HL-CYB-001 | Implementation PLANNED | Operational controls NOT TESTED | Owner user acceptance testing (UAT) PENDING

Build an isolated lab that lets an analyst read reports, an engineer read maintenance instructions and an unassigned user receive a denial. This guide explains how to prepare, configure and check the four-week assignment. No installation or working control is established by these instructions.

Guide contents

1. Before beginning the lab 1
2. Phase 1: Infrastructure and Network 2
3. Phase 2: Identity and Endpoint Security 5
4. Phase 3: Zero Trust Access Controls 7
5. Phase 4: Monitoring, Automation and Recovery 12
6. Phase 5: Validation and Final Submission 15
7. Required lab deliverables 17
8. Historical requirement and test transition 17

1. Before beginning the lab

1. Read the architecture, security requirements and test plan. FWR identifies a requirement; FWT identifies its test. Keep actual results empty until execution.
2. Before **each stage A-L**, obtain explicit owner approval naming scope, exact assets, permitted changes, validation, private evidence handling and rollback. Record its reference/date in the private change record and a sanitized engineering report. A document, previous approval or pull request does not approve the next stage.
3. Confirm selected versions, media integrity, lawful terms and installed help. Navigation below follows vendor documentation reviewed on 2026-11-06. Verify labels against the installed release; stop and resolve a mismatch before applying changes.

Phase	Separate stage approvals	Week
1: Infrastructure and Network	A readiness; B host; C networking; D virtual firewall	1
2: Identity and Endpoint Security	E directory; F endpoint/server baselines	2
3: Zero Trust Access Controls	G simple CA; H application roles; I Tailscale	2-3
4: Monitoring, Automation and Recovery	J monitoring; explicitly approved L automation/recovery portion	3-4
5: Validation and Final Submission	K validation; remaining L closeout portion	4

Only the approved automation/recovery portion of L may precede K. Allow 8-12 focused hours weekly after readiness approval. Delivery, isolation, activation or recovery gaps move dates; they do not relax controls.

Command labels: READ-ONLY inspects state; CONFIGURATION CHANGE writes settings/files; DESTRUCTIVE / HIGH-RISK can erase data, change trust or expose connectivity. Every example is proposed reference text for a future approved stage. Run only on its named lab target. Copy commands from Markdown; PDF wrapping is visual. Replace symbolic addresses, paths and selected service names privately; never paste credentials into commands or Git.

Stop and recover: uncertain disks/assets, unexpected home/production connectivity, secret output, failed safety checks or missing rollback stop the affected work. Disconnect approved egress using the agreed console procedure, preserve private evidence and obtain a bounded correction approval. No probes of home or production are permitted.

2. Phase 1: Infrastructure and Network

A. Objective

Prepare compatible hardware and build one recoverable Proxmox host, one virtual firewall and three isolated zones. Complete readiness before any installer is opened.

B. Prerequisites

- Stage A read-only approval; separate B-D approvals before their changes.
- **Existing:** owner-described Dell Precision 5820 (W-2125, 80 GB RAM, 512 GB SSD), Lenovo laptop, HP desktop, test laptops, Google Wifi and available thermal paste. This is not a readiness finding.
- **Ordered:** Xeon W-2145, Samsung 1 TB SSD, Sabrent PCIe adapter, Intel I350-T4 NIC, GL.iNet Beryl AX and TP-Link managed switch, per the latest owner procurement plan and 2026-11-06 correction. Do not reorder them.
- **Delivered:** unconfirmed. Expected dates remain November 7, 2026 for non-CPU items and November 12 for the CPU; estimates are not receipt.
- **Installed:** unconfirmed; do not assume Proxmox or other lab software exists. **Validated:** no hardware-readiness or operational evidence.
- Before installation: confirm delivery, inspect condition/part identity, verify CPU/cooler/firmware and SSD/adapter/slot compatibility, inventory existing data/services, verify backup/recovery and obtain exact destructive-target approval.
- Preserve the original Windows disk and existing data/services. Shutdown or migration needs its own approval. Extra hardware does not require VLANs, physical OPNsense or extra zones.

C. Required tools

Existing firmware/storage screens, physical console, private disk/cable ledger, official verified installation media, credential store and recovery media. Stage A installs no inspection software. Use Proxmox documentation matched to the selected release.

D. Step-by-step implementation

1. **A - READ-ONLY, existing candidate at its console:** compare observed CPU/RAM/virtualization, disk identity/contents/free space and NICs with the private ledger. Date Existing/Ordered/Delivered/Installed/Validated separately. If a required part or recovery copy cannot be verified, record a no-go.
2. Review current services, data and availability needs with the owner. Confirm recovery media and access to the backup. Exclude protected workloads before host transition.

3. Recalculate the capacity budget: four VMs, 20 GiB guest RAM/176 GiB disks, 12 GiB host RAM and 80 GiB free storage reserved, plus media and temporary restore space. Thin provisioning does not create capacity.
4. Draw the cable/bridge map. Dedicate the admin path to the lab. Inspect Wi-Fi, other NICs, VPNs and Internet sharing; disable unapproved forwarding under the relevant approval. Keep external access disconnected. A Beryl AX/home-LAN uplink or NAT alone does not prove independent isolation.
5. **B - DESTRUCTIVE / HIGH-RISK, physical host console:** boot verified Proxmox media only after exact-disk and backup/recovery approval. Match the installer target to the approved model/capacity/serial in the private ledger immediately before selection. Never select the preserved Windows disk or a substitute. If ambiguous, exit before confirming installation.
6. After approved installation, verify the host boots locally. From the dedicated isolated admin station, open its displayed management address. Select the host in the left tree, then **Disks** and the storage object's **Summary** to compare actual capacity/identity. Use **Datacenter > Storage** to inspect the selected storage; creating/wiping storage requires exact approval.
7. Configure named scoped administration and supported multi-factor authentication (MFA)/recovery. Use root only for necessary setup/recovery. Record build, updates and console recovery. Do not create a cluster.
8. **C - CONFIGURATION CHANGE, host web interface with console available:** select the host, **System > Network**. Inspect vmbr0; create/edit Linux bridges vmbr10 and vmbr20. Only vmbr0 has the approved isolated physical admin port and host address. Corporate/Restricted have no physical ports, host addresses or uplink. Save the old settings; review pending changes before **Apply Configuration** or the installed release's equivalent.
9. **D - CONFIGURATION CHANGE, Proxmox:** choose **Create VM**; select the approved node/unused VM ID, verified OPNsense ISO and approved storage. Set 2 vCPU, 4 GiB RAM, 16 GiB disk. Verify supported virtual disk/NIC types for the selected guest release. Do not start until its interfaces are reviewed.
10. Select the firewall VM, **Hardware**. Assign one virtual NIC to each of vmbr0/vmbr10/vmbr20, using **Add > Network Device** as needed. Record each MAC and bridge. Open **Console**, start the VM and install only to its virtual disk. Optional WAN stays disconnected; no inbound forwarding.
11. In the OPNsense interface settings, open **Interfaces > Assignments**. Match devices to recorded MACs, name the three zones and enter the approved private interface addresses. Device names vary. Review and apply from console-supported access; inspect private/bogon settings for the actual interface role.
12. In **Firewall > Rules**, select the traffic's incoming interface and implement FF-01 through FF-08. Enter action, interface, direction, protocol, exact source/destination and destination service; log relevant denies. Keep the named management allow before narrowing broad installer permits. Current rule guidance distinguishes modern rules from legacy screens: verify sort order, quick behavior and effective automatic/floating/group rules.
13. Inspect states, NAT, DNS, routed IPv6, firewall-originated traffic and UPnP/NAT-PMP. Retest approved affected flows after handling only their stale states; do not clear all states casually. Keep FF-07 egress disconnected until independently isolated access is separately approved.
14. Open **System > Configuration > Backups**; export a password-protected configuration to approved private storage. Confirm its date/recovery custody. Check relevant denies under **Firewall > Log Files > Live View**, filtering by lab interface/source/service.

READ-ONLY - Windows candidate, local PowerShell; standard user normally sufficient, approved elevation only if access is denied. These queries show local hardware and adapter settings. No replacement values. Output stays private:

```
Get-CimInstance -ClassName Win32_ComputerSystem
Get-CimInstance -ClassName Win32_Processor
Get-NetIPConfiguration -All
```

Confirm: compare CPU/RAM and adapter/gateway data with firmware/screens and the cable map. Missing permissions or inconsistent values block readiness; these queries do not prove physical delivery, disk safety or network isolation.

E. Expected results

Readiness is evidenced first. After separately approved B-D work, one host/firewall and three zones have a recoverable admin path, measured capacity and no protected-network path.

F. Verification checklist

- FWT-01/FWT-02: compare cables, bridge/NIC membership, routes, IPv6, private aliases and effective rules.
- Demonstrate permitted/denied bounded flows to known listening **lab-owned mocks**, with matching logs/counters. Repurpose approved guests/console; add no permanent VM and never probe home/production.
- Confirm named administration, ordinary-user denial and console recovery. A disconnected target alone does not prove a deny rule.

G. Troubleshooting

Lost administration: use console to inspect MAC/bridge mapping and the specific management allow. Unexpected permit: disconnect approved egress and inspect state/automatic rules/forwarding. Uncertain compatibility, disk or backup means no installation; do not substitute a disk or home uplink.

H. Rollback / recovery

A changes nothing. For B-D, use the approved console plan to restore saved host/network/firewall settings and reverify isolation before egress. Destructive reinstall or hardware recovery needs explicit coverage; preserve the original disk, data and evidence.

3. Phase 2: Identity and Endpoint Security

A. Objective

Create the Windows lab directory and supported Windows/Linux guests. Keep standard work separate from administration and Windows logon separate from application authorization.

B. Prerequisites

- Phase 1 verified; E directory and F endpoint/server approvals.
- Supported lawful Windows Server, domain-capable Windows endpoint and Linux media; guest CPU/disk/virtual TPM requirements checked.
- Approved update/activation path, private addresses/DNS/time, recovery credentials and selected Linux network/firewall backend. Missing safe activation remains a blocker.

C. Required tools

Proxmox Console; Server Manager; Active Directory Users and Computers; DNS Manager; Group Policy Management; Windows Security/firewall console; the selected Linux distribution's supported network/firewall interface. Record actual package/service names and configuration paths during approval; do not add a different manager to match an example.

D. Step-by-step implementation

1. In Proxmox **Create VM**, select the approved node, unused VM ID, media and storage. Create DC1 on vmbr10 (2 vCPU/6 GiB/64 GiB), WIN1 on vmbr10 (2/6/64) and APP1 on vmbr20 (2/4/32). Review each **Hardware > Network Device** bridge/MAC and single zone NIC before first start. Use **Console** for installation/recovery.
2. Install the approved operating systems only to their virtual disks. Name the guests DC1/WIN1/APP1; record builds, update status and evaluation deadlines. Configure approved lab time; never use corporate activation keys or protected services.
3. On DC1, use **Server Manager > Local Server** to review its name and Ethernet settings. Set its approved fixed address/prefix, zone-firewall gateway and lab-only DNS plan through the adapter properties. Confirm identity/address/time at console before promotion.
4. **E - DESTRUCTIVE / HIGH-RISK, DC1 local Administrator:** open **Server Manager > Manage > Add Roles and Features**, select role-based installation and DC1, then **Active Directory Domain Services** with management tools. After installation use the notification **Promote this server to a domain controller**, choose **Add a new forest**, and enter **ad.lab.test**. Retain DNS; securely enter the Directory Services Restore Mode recovery password. Review paths/prerequisites and allow the approved reboot. Microsoft deployment guidance governs installed-version choices. Use the GUI or equivalent commands below, not both as repeated deployment.
5. On DC1, **Server Manager > Tools > Active Directory Users and Computers**: expand ad.lab.test, create organizational units for users, privileged identities and lab computers. In the chosen unit use **New > User** for ava, eli, uma and the separate named privileged administrator; set prompted private passwords. Secure built-in/service accounts separately; they are not extra project personas.
6. Use **New > Group**, Security type and approved scope, to create LabReaders, LabMaintainers and LabAdmins. In group **Properties > Members**, put ava/eli in LabReaders, eli in LabMaintainers and only the privileged administrator in LabAdmins. Assign only approved administrative rights; a custom group name alone grants none. Inspect unintended privileged memberships.

7. In **Server Manager > Tools > DNS**, expand DC1 > **Forward Lookup Zones > ad.lab.test**. Inspect DC/service records. Use **New Host (A or AAAA)** for app, entering APP1's approved Restricted address. Confirm name/address in the DNS record view; do not configure corporate forwarding.
8. On WIN1, set its adapter to lab DNS only. Open **System Properties > Computer Name > Change**, select **Domain**, enter ad.lab.test and provide only the approved lab join credential. Review the domain-join confirmation, restart, then sign in as a standard lab user. The join procedure varies by Windows edition/release; no cloud/production join.
9. **F - CONFIGURATION CHANGE, DC1 Group Policy Management:** link the approved endpoint pilot policy to lab computer units. Under **Computer Configuration > Policies > Windows Settings > Security Settings**, configure scoped firewall/audit settings using the release's Windows Firewall with Advanced Security node. Keep profiles enabled, supported antivirus, separate privileges and recovery access. Apply approved domain password/lockout policy through a GPO linked at the ad.lab.test domain root; an OU-only link does not enforce domain-account passwords. Audit logon/account changes and DC Kerberos Authentication Service success/failure.
10. On WIN1, inspect **Windows Security > Firewall & network protection** and the effective policy. In **Computer Management > Local Users and Groups > Groups > Administrators**, confirm standard lab users are absent. Inspect resultant policy in the approved policy view; never test lockout through repeated password attempts.
11. On APP1's Proxmox console, configure its approved address/prefix, Restricted gateway, DC1 DNS and lab time using the selected distribution's recorded network interface/configuration. Match the NIC by MAC. For an approved Ubuntu release using Netplan, preserve the existing /etc/netplan YAML before editing those fields with the approved privileged editor; verify its activation/recovery procedure first. Inspect effective addresses/routes/resolver after applying. APP1 does not join AD.
12. In APP1's recorded host-firewall tool, preserve the current rules, allow HTTPS only from approved local/overlay sources and administration only from the dedicated path, then enable/review default-deny input and disabled forwarding. Apply from console; verify listeners/rules separately. Tailscale rule precedence is checked again in Phase 3. Exact backend/menu/activation commands require the installed distribution's documentation before approval.

DESTRUCTIVE / HIGH-RISK - DC1, elevated Windows PowerShell as local Administrator, E approval. Alternative to step 4: installs AD tools and creates the lab forest, prompting securely for recovery credentials and potentially rebooting. Keep ad.lab.test as the approved synthetic name; no private replacement value or inline password:

```
Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools
Install-ADDSForest -DomainName 'ad.lab.test' -InstallDNS
```

Confirm: review role/forest prerequisite output, complete the approved reboot and inspect AD/DNS in Server Manager. A feature-install success alone does not prove promotion. If prerequisites fail, stop; do not add bypass flags or demote/rebuild casually.

READ-ONLY - WIN1 domain member, elevated Windows PowerShell, lab administrator. Run `Test-ComputerSecureChannel -Verbose` to check the member's lab-domain channel. No replacements; expect True and a healthy-channel message. Confirm separately through standard logon and DNS/policy views. False means inspect DNS/time/rules first; do not add -Repair without approval. This command is not a DC health check.

E. Expected results

One lab AD/DNS/Group Policy directory, three standard users/groups, one separate privileged administrator, a Windows member and a hardened Linux app server. Application roles remain separate.

F. Verification checklist

- FWT-03/FWT-04: compare directory counts, memberships and DNS to standard WIN1 logon/name resolution and resultant policy.
- Inspect patch/antivirus/firewall state, single zone NICs, trust/cloud/resolver settings and standard-user privilege denial with an approved harmless admin control.
- Record supported directory recovery as a dependency. A snapshot is not proof of AD disaster recovery.

G. Troubleshooting

Join/logon/policy failure: inspect lab DNS/service records, time and host rules. WIN1/DC1 share Corporate, so OPNsense does not mediate that traffic. A missing Linux backend/path or rejected setting requires vendor/version review, not a broad permit or firewall disable.

H. Rollback / recovery

Restore only changed pilot policy, memberships and host/network settings through retained console/admin access. Forest demotion/rebuild or directory restoration requires a separately approved supported plan; do not casually revert DC snapshots.

4. Phase 3: Zero Trust Access Controls

A. Objective

Protect two synthetic HTTPS paths with separate application accounts, then restrict remote access to that one application. Demonstrate real denial after role/device revocation.

B. Prerequisites

- Phase 2 verified; separate G certificate, H application and I remote-access approvals.
- app.ad.lab.test and the frozen six-case matrix; private key/password custody and approved lab-client trust.
- For Tailscale: independently isolated approved Internet, separate lab tailnet/identities, supported MFA/recovery and current lawful terms. Otherwise remote work remains NOT TESTED.

C. Required tools

Existing approved signing workstation, OpenSSL 3.x, APP1 Apache HTTP Server 2.4, local administrator/editor, lab browsers, AD group view and Tailscale client/admin console. Verify installed help, modules, package paths and service controls before changes; no CA, connector or extra permanent VM.

D. Step-by-step implementation

Create and check the lab certificate

1. **G - CONFIGURATION CHANGE, offline signing workstation:** prepare private owner-only storage outside Git. The CA key stays encrypted/offline. Define the approved private paths below; inspect existing contents to avoid overwriting keys/certificates/serial state.
2. Generate one root CA using the command below. Keep the prompted passphrase in approved recovery custody. Copy only the public root to authorized transfer media.

3. On APP1, generate its service key and certificate signing request (CSR) in restricted storage. Inspect request identity and intended paths, then transfer the reviewed CSR to the offline signer. Never transfer APP1's private key.
4. On the signer, create the leaf extension file below and sign the reviewed CSR. Return the public leaf and root to APP1/approved clients. Inspect chain, hostname and dates before configuring the service.
5. On approved Windows lab clients, import only the public CA into the selected lab trust store, using **Manage computer certificates > Trusted Root Certification Authorities > Certificates > All Tasks > Import** for explicitly approved computer-wide trust; Microsoft's store guidance explains the certificate console. Check the root fingerprint against the signer. Never import into a home/production trust store or move DC time to test expiry.

CONFIGURATION CHANGE - offline signer, local POSIX shell as the private signing-file owner; root not required. `LabCaKeyPath` and `LabCaCertPath` are reviewed new private key/public-root paths. Creates a 3072-bit encrypted CA key and 365-day self-signed root; password entry is interactive. OpenSSL req documents the selected-version options:

```
openssl req -x509 -newkey rsa:3072 -sha256 -days 365 -keyout "$LabCaKeyPath" -out
"$LabCaCertPath" -subj "/CN=HL-CYB-001 Lab CA" -addext "basicConstraints=critical,CA:TRUE"
-addext "keyUsage=critical,keyCertSign,cRLSign"
```

Confirm: inspect CA constraints/key usage and public-root identity with the selected OpenSSL certificate view; confirm the key is encrypted without displaying it. Stop on overwrite/path/passphrase problems.

CONFIGURATION CHANGE - APP1 Linux console, root or approved administrator controlling the service-key directory. `LabAppKeyPath` and `LabAppCsrPath` are approved new paths. Creates a 2048-bit unencrypted service key and CSR, not a signed certificate. Restrict owner/read permissions before generation and retain only required service access:

```
openssl req -new -newkey rsa:2048 -noenc -keyout "$LabAppKeyPath" -out "$LabAppCsrPath"
-subj "/CN=app.ad.lab.test"
```

Confirm: inspect CSR subject and key-file ownership/permissions privately. -noenc intentionally leaves the service key unencrypted; filesystem restrictions and encrypted backup protect it. Do not expose key contents.

CONFIGURATION CHANGE - offline signer, signing-file owner; root not required. Save this exact extension content at the private `LabLeafExtensionsPath`; it is a configuration file, not a shell command:

```
basicConstraints=critical,CA:FALSE
keyUsage=critical,digitalSignature,keyEncipherment
extendedKeyUsage=serverAuth
subjectAltName=DNS:app.ad.lab.test
```

Confirm: CA:FALSE, serverAuth, key usage and the app.ad.lab.test DNS subject alternative name (SAN) match the intended leaf. A different hostname requires review before signing.

CONFIGURATION CHANGE followed by READ-ONLY - offline signer, same file owner. The first command signs the reviewed CSR for 90 days and maintains the private `LabSerialPath`; `LabAppCertPath` is the new public leaf. The remaining commands inspect chain/hostname/dates/SAN without changing files. All other path variables are those above:

```
openssl x509 -req -in "$LabAppCsrPath" -CA "$LabCaCertPath" -CAkey "$LabCaKeyPath"
-CAcreateserial -CAserial "$LabSerialPath" -days 90 -sha256 -extfile
"$LabLeafExtensionsPath" -out "$LabAppCertPath"
openssl verify -CAfile "$LabCaCertPath" -verify_hostname app.ad.lab.test "$LabAppCertPath"
openssl x509 -in "$LabAppCertPath" -noout -dates -ext subjectAltName
```

Confirm: chain verification returns OK; displayed SAN and dates match. Inspect the issued certificate's CA:FALSE/serverAuth properties too. Stop on failed verification; do not bypass browser warnings. A real browser TLS session is the second observation. Certificate-revocation infrastructure is excluded; account/device revocation remains required.

Configure and verify application roles

1. **H - CONFIGURATION CHANGE, APP1 root/approved service administrator:** create root-owned synthetic pages under /srv/labapp/reports and /srv/labapp/maintenance. Maintenance means reading instructions, not obtaining a shell or making a real operational change.
2. Install/configure only the approved Apache package/modules through the approved media/update path. Verify TLS, file authentication and group authorization modules. Use the distribution's configuration directory; Ubuntu's example uses /etc/apache2 with sites-available/sites-enabled and mods-available/mods-enabled. Other distributions differ; record actual activation and log/service paths.
3. Create /etc/labapp outside the document tree with restricted ownership. As root, `htpasswd -B -c /etc/labapp/users ava` creates the bcrypt password file once. This is **DESTRUCTIVE / HIGH-RISK if the file already exists**: -c overwrites records. Add eli with `htpasswd -B /etc/labapp/users eli`, and uma the same way without -c. Prompts take distinct app passwords, never AD passwords. No private value belongs in the command line.
4. Save the group file below as /etc/labapp/groups. Make both files readable only by the required administrator/service account. Inspect the three account names and memberships privately without displaying hashes. A failed htpasswd write is not success; preserve the old file and resolve permissions first.
5. Save the reviewed virtual host fragment below in the distribution's site configuration. Match public certificate/key paths to the approved files. Add Listen 443 once, disable default/plain-HTTP sites and directory listing, and configure secret-free access/error logs. Verify the package's activation procedure before reload.
6. Run the syntax check described below, activate/reload through the recorded service control, then open https://app.ad.lab.test/reports/ and /maintenance/ from the approved lab client. Execute C01-C06 with known valid app credentials, recording allowed content or the intended denial.
7. Remove eli from application LabMaintainers and the corresponding AD group under the approval. Retry both an authenticated browser and a fresh maintenance request; both must deny. Record time/cache treatment and correlated authorization logs. Restore membership only if approved.

CONFIGURATION CHANGE - APP1, root/approved editor. Group-file content, not shell commands:

```
LabReaders: ava eli
LabMaintainers: eli
```

AD manages Windows lab identities. The app uses **separate test accounts, distinct passwords and manually assigned roles**. LabAdmins is infrastructure-only. AD changes alone do not revoke app permissions; enterprise single sign-on and automatic synchronization are excluded.

CONFIGURATION CHANGE - APP1 Apache 2.4 site file, root/approved editor. The paths are the approved lab layout; adapt only through review if the selected package differs. This fragment enables TLS and authorizes each child directory by its group:

```
<VirtualHost *:443>
    ServerName app.ad.lab.test
    DocumentRoot "/srv/labapp"
    SSLEngine on
    SSLCertificateFile "/etc/labapp/app.crt"
    SSLCertificateKeyFile "/etc/labapp/app.key"
    SSLProtocol -all +TLSv1.2 +TLSv1.3
    <Directory "/srv/labapp">
        Options -Indexes
        AllowOverride None
        AuthType Basic
        AuthName "HL-CYB-001"
        AuthBasicProvider file
        AuthUserFile "/etc/labapp/users"
        AuthGroupFile "/etc/labapp/groups"
        AuthzSendForbiddenOnFailure On
        Require all denied
    </Directory>
    <Directory "/srv/labapp/reports">
        Require group LabReaders
    </Directory>
    <Directory "/srv/labapp/maintenance">
        Require group LabMaintainers
    </Directory>
</VirtualHost>
```

AuthMerging Off lets child authorization replace the parent denial. Inspect inherited/global settings; do not replace group checks with broad Require valid-user.

READ-ONLY - APP1 Linux, root/approved service administrator: `apachectl configtest` parses configuration; the distribution's wrapper may differ. No replacement values after selecting the correct wrapper. Expect Syntax OK, then use the recorded service control for the separately approved **CONFIGURATION CHANGE** reload. Confirm service status in that control and actual HTTPS/role behavior. Syntax OK alone proves neither authorization nor a running service; restore the saved site if parsing/reload fails.

Restrict and revoke remote access

1. **I - DESTRUCTIVE / HIGH-RISK enrollment/trust change:** sign into the separate lab Tailscale admin console with the approved owner identity/MFA. Confirm recovery and isolated egress first. Open its access-policy editor and preserve the old policy privately.
2. Before enrollment, save a reviewed deny-all policy with explicit `"acls": []` and no grant/SSH allows. Do not leave the policy empty or reset to defaults. Inspect every additive grant/ACL and tag owner; an extra allow can broaden access.
3. Use the official selected-OS client enrollment flow on APP1 and one approved lab client; verify the tailnet identity before completing sign-in. Compare both **Machines** entries. After identifying exact APP1, add the reviewed grant for the approved lab source, exact APP1 destination and `tcp:443`. No production identity, key or tailnet is used.
4. Keep subnet advertisements, exit nodes, public sharing, Tailscale SSH/Funnel/Serve and forwarding off. Inspect effective Linux overlay rules and vendor precedence. OPNsense alone cannot establish overlay restriction.

5. Map app.ad.lab.test privately to APP1's overlay address on the remote client; local clients retain the zone address. Do not publish addresses. Verify allowed HTTPS, unauthorized context and wrong resource/listening port using the frozen FWT-06 scope.
6. Remove client authorization/grants or use **Machines > approved client's menu > Remove**, confirming the exact lab device. Compare device removal and effective policy to existing/fresh request denial. Record actual elapsed time. Stop on broader access; do not add allow-all or broad routes.

READ-ONLY - enrolled APP1 or approved lab client, local terminal/PowerShell; standard operator where supported. `tailscale status` shows connection/device state; no replacements. Expect only the approved lab context. Compare to Machines and the actual permitted/denied sessions. Output contains private addresses/identity data; keep it private. A status listing does not prove access control.

E. Expected results

One CA/leaf, two protected paths, six role cases, real app revocation and one-resource remote permit/deny/revoke evidence. No AD SSO, universal MFA or enterprise certificate-lifecycle claim.

F. Verification checklist

- FWT-03/FWT-05/FWT-06: compare effective app roles/logs with allowed content and authenticated denials, normally 403 for this configuration.
- Check chain/name/dates and rejection by an otherwise working untrusted lab client.
- Compare vendor/host policy to actual remote HTTPS, wrong listening-port denial and revoked existing/new sessions. Record cache/state treatment and actual time.

G. Troubleshooting

TLS: inspect SAN/chain/dates/trust/private DNS; warning bypass is not PASS. App: inspect group spelling, inherited rules, logs and cached browser credentials; AD does not update app roles. Remote: inspect lab tailnet, additive policy, overlay rules and approved egress; never relax to broad routes.

H. Rollback / recovery

Restore saved site/group settings, syntax-check and reload through the recorded control. Remove trust only from approved lab clients. Disable remote grant/device, stop the client and restore private DNS/routes/egress under approval. Preserve failures; exposed keys use the owner's authorized credential process.

5. Phase 4: Monitoring, Automation and Recovery

A. Objective

Explain five benign security events, automate one local capacity summary and prove an isolated APP1 restore with measured limits.

B. Prerequisites

- J monitoring and the specific L automation/recovery approvals; no implicit approval of remaining closeout.
- Private event records, one approved local target/output, encrypted off-compute storage, recovery-key access and temporary restore capacity.
- Approved disconnected restore bridge/VM ID and exact APP1 scope. No AD, CA or host disaster-recovery claim.

C. Required tools

OPNsense Live View, DC1 Event Viewer, Apache access/error logs, existing PowerShell/Python, Proxmox Backup/Restore, encrypted media, existing hash tools and an independent clock. No SIEM or collector VM.

D. Step-by-step implementation

1. **J - CONFIGURATION CHANGE, source log settings:** select firewall, DC1 Security and Apache access/error sources. Using only two requires an approved selection that still covers all five categories. Restrict record access/export and bound rotation to disk capacity; record source/observer UTC and clock differences.
2. In OPNsense **Firewall > Log Files > Live View**, filter the named lab source/destination/service and inspect the rejecting rule. Logging must be enabled for that rule or the relevant global setting. Existing states may not produce a new-rule log.
3. On DC1 open **Event Viewer > Windows Logs > Security > Filter Current Log**. After confirming the approved audit settings, filter candidate Kerberos events 4768/4771. Produce a real online WIN1 lab-domain logon and one single failed logon in a disposable synthetic context, then match actual records. Cached/offline sign-in is not directory success; no password attack.
4. On APP1 open the recorded package-specific Apache access/error logs with the approved privileged viewer. Produce an app allow and authenticated app denial. Produce one firewall denial to a known listening lab service within the frozen scope. These are five distinct categories, not five duplicate requests.
5. Record event type/context, source/observer time and private evidence ID. Investigate one denial: requested resource/action, rejecting rule/group, working allowed control, correlated source record and conclusion. Retain the actual evidence; no enterprise latency/retention target applies.
6. **L automation - CONFIGURATION CHANGE to one private output, WIN1:** review the proposed capacity-summary script below before saving it privately. Approve the exact hostname/domain/output directory and rejection checks. No remote credentials or configuration change is required.
7. Run it in local PowerShell as described below, compare bytes to **File Explorer > This PC > drive Properties** or the approved storage view, then repeat. Only WIN1-capacity.json may be replaced. Inspect configuration/side effects and safely confirm invalid targets/paths produce no output; changing free space does not itself show a defect.

8. **L recovery - DESTRUCTIVE / HIGH-RISK restore, Proxmox:** define the APP1 manifest: pages, Apache configuration, hashed users/groups, server key/leaf and public root. Verify encrypted **off-compute** backup storage and separate recovery-key custody. Ordinary Proxmox archives are not encryption; same-disk snapshots do not qualify.
9. In Proxmox, inspect **Datacenter > Storage** and the approved storage's capacity/status. Stop if the planned encrypted target is unavailable; do not format substitute media. Cleanly shut down APP1 through its console and confirm stopped state.
10. Select APP1 > **Backup > Backup now**, choose the approved storage and reviewed stop/consistency mode, then run the backup. Open the task log and confirm completion/manifest coverage/readability. Keep APP1 off for the restore drill and preserve the only valid backup.
11. Select the approved backup storage > **Backups**, choose the exact APP1 archive and **Restore**. Enter the approved unused temporary VM ID and target storage; review all fields before confirming. Do not overwrite the original ID or select automatic start/live restore. Proxmox backup guidance governs release-specific behavior.
12. Before starting the restored copy, inspect **Hardware > Network Device** and disconnect every NIC; set **Options > Start at boot** off. Keep original APP1 off. Start the copy via **Console** and disable its copied Tailscale service through the recorded OS service control before any isolated attachment.
13. Record restore start and time to usable service using the independent clock. Compare hashes/content to the private manifest. Check HTTPS and allowed/denied roles through console or an approved existing client on a disconnected test bridge. If repurposing WIN1, record and later restore its bridge attachment; never attach the copy to Management/home.
14. Record backup age, elapsed recovery, scope/verdict and exclusions. Leave the copy disconnected. Resuming the original or deleting the copy needs approved cleanup; a temporary recovery copy adds no permanent baseline VM.

CONFIGURATION CHANGE - WIN1, local Windows PowerShell; standard user with permission to query local capacity and write the approved directory. Proposed private script; save/run only after L approval. It reads capacity and replaces one named JSON output. `OutputDirectory` must be an existing reviewed private directory outside every Git checkout. The hostname/domain checks stay WIN1/ad.lab.test:

```
param([Parameter(Mandatory)][string]$OutputDirectory)
$system = Get-CimInstance -ClassName Win32_ComputerSystem
if ($system.Name -ne 'WIN1' -or $system.Domain -ne 'ad.lab.test') {
    throw 'Target is outside the approved lab operation.'
}
$directory = Get-Item -LiteralPath $OutputDirectory -ErrorAction Stop
if (-not $directory.PSIsContainer) { throw 'Output must be a directory.' }
$cursor = $directory
while ($null -ne $cursor) {
    if (Test-Path -LiteralPath (Join-Path $cursor.FullName '.git')) {
        throw 'Keep the capacity record outside Git.'
    }
    $cursor = $cursor.Parent
}
$capacity = Get-CimInstance -ClassName Win32_LogicalDisk -Filter 'DriveType=3' |
    Select-Object DeviceID, Size, FreeSpace
$capacity | ConvertTo-Json |
    Set-Content -LiteralPath (Join-Path $directory.FullName 'WIN1-capacity.json') -Encoding
utf8
```

Run/confirm: from WIN1, `& $LabCapacityScriptPath -OutputDirectory $LabCapacityOutputDirectory` invokes the reviewed script. Set those two variables privately to the approved script file/directory; no credential argument is used. Expect WIN1-capacity.json containing DeviceID, Size and FreeSpace in bytes. Compare to the storage UI, inspect the intended replacement after two runs and verify safe rejection. Stop on target/path/units errors. The path check does not replace review of actual storage, links or permissions.

READ-ONLY - APP1 Linux console, approved log-reader; root/elevation only when journal permissions require it. This systemd query shows records since local midnight without a pager; no replacement values:

```
journalctl --since today --no-pager
```

Confirm: match timestamps/service messages to the approved action and recorded timezone. Apache request logs use a separate verified package path; an empty system journal is not proof of no web requests. Keep output private; if permission/time filters hide records, resolve the view before producing another event.

E. Expected results

Five attributable events, one explained denial, one safely repeatable operation and one successful isolated APP1 restore with actual measured limits.

F. Verification checklist

- FWT-07: compare each source record to the actual approved action and a separate policy/group observation.
- FWT-08: compare output to the OS storage view, inspect unchanged configuration and verify repeat/rejection behavior.
- FWT-09: compare backup/restore log to independent clock, hashes/content and real restored HTTPS/role behavior. State that AD/CA/host recovery and enterprise RPO/RTO were not tested.

G. Troubleshooting

Missing logs: inspect audit selection, filters, time and rotation. Automation mismatch: inspect target/path/units before retry. Restore failure: keep original and backup safe, inspect decryption/storage/version/mode in isolation and preserve the failure. Do not reconnect to bypass a dependency.

H. Rollback / recovery

Restore only changed audit/rotation settings without clearing logs. Remove only the intended summary if approved. Keep the restore copy off/disconnected and resume the original only through approved cleanup/isolation checks. Never overwrite the sole backup or delete evidence.

6. Phase 5: Validation and Final Submission

A. Objective

Complete all mandatory test evidence, submit accurate results and obtain a separate owner acceptance decision.

B. Prerequisites

- K validation and remaining L closeout approvals, frozen cases, implementation records, current backup and private evidence custody.
- Use the five released blank templates in required records. Fill them only during approved work; template availability supplies no lab result or stage approval.

C. Required tools

Ten-test catalog, acceptance criteria, approved lab clients/policy/log views, evidence index and released submission templates. Repository Git/Python checks support publication only.

D. Step-by-step implementation

1. Freeze versions, lab-owned targets, synthetic user contexts, expected outcomes, second observations and rollback. Follow each FWT subcheck; do not change an expectation to hide failure.
2. Execute the ten approved tests within the stage scope, including six app cases/revocation, remote permit/deny/revoke, HTTPS, events, automation and restore. No scans or protected targets.
3. Record actual action/result/time/version/verifier/evidence and a second observation. Mark each subcheck PASS, FAIL or NOT TESTED. A timeout without a working control and intended-denial evidence is insufficient.
4. Map FWR-01 through FWR-10 to test evidence and defects. Missing mandatory checks block engineering completion; critical safety failures block acceptance. Preserve failures and obtain bounded remediation/retest approval.
5. Complete the five required records when released. Store each detail once and cross-reference it. The project final report remains a template until real implementation/reporting is authorized.
6. On the approved publication workstation, review the complete proposed public set, file contents/metadata, staged diff and new history. Keep credentials, actual addresses, private inventory, logs, keys/backups and filled private working records outside Git. Independent human review requires another participant.
7. Run documentation-only checks below, inspect all changed PDF pages and resolve findings. Follow the publication workflow: reviewed task branch/commits, pull request, completed-head CI/reviews/rules, normal permitted merge with verified noreply author/committer, then fast-forward main and compare live commit IDs. Do not force or bypass requirements.
8. Ask the owner to assess the intended workflows and understandable evidence/recovery records. Record the explicit UAT confirmation reference/date separately. No score, engineering check or CI pass supplies acceptance. Stop at the approved boundary.

READ-ONLY validation - Windows publication workstation, repository root, existing pinned documentation Python environment; administrator access not required. These commands inspect documentation/Office packages, render fresh PDFs in memory for comparison and run temporary documentation fixtures. They do not execute lab examples. No replacement values after selecting the approved environment:

```
python scripts/validate_docs.py --require-finalized
python scripts/validate_office_templates.py
python scripts/build_docs.py --check --rebuild-check
python -m unittest discover -s tests -v
git diff --check
```

Confirm: all checks exit successfully; the finalized-report gate accepts the evidence record, PDFs match their Markdown and history/Office preservation checks pass. Read actual output; do not treat these checks as lab-security results. If dependencies are absent, use the build guide; if a check fails, correct editable source and inspect again before publication.

E. Expected results

Complete evidence, accurate grading, sanitized submission and a separate owner decision. Planned work earns no implementation credit; unexecuted actuals remain empty.

F. Verification checklist

- FWT-10: trace every mandatory test/subcheck, requirement/control, evidence item and defect to the correct record.
- Use the assignment's single 100-point rubric, unchanged at 25/25/20/20/10.
- Verify actual PR/CI/merge/local-remote synchronization. Owner UAT stays PENDING without explicit confirmation.

G. Troubleshooting

Fix link/PDF problems in editable Markdown/build code and regenerate; never hand-edit hashes. Satisfy reviews/checks without bypass. Missing templates, operational evidence or UAT remain pending and block the corresponding completion claim.

H. Rollback / recovery

Use reviewed reverts that preserve finalized records/evidence. End temporary policies/tests only under approved cleanup. Never rewrite history, delete owner work or start another stage just to close a report.

7. Required lab deliverables

These five files are **available as blank templates** in the deliverable library. Complete them during approved work and link reviewed evidence; current actual results remain empty.

Filename	Owning record
01-Lab-Environment-and-Architecture.xlsx	Readiness, four VMs/three zones, flows and capacity
02-Identity-and-Zero-Trust-Implementation.docx	AD/groups, endpoints, HTTPS, six app cases and remote revocation
03-Security-Monitoring-and-Testing.xlsx	Five events, investigation, tests, automation and restore
04-Troubleshooting-and-Lessons.xlsx	Defects, fixes/retests and lessons
05-Final-Project-Submission.docx	Results/index, rubric, limits and separate UAT

8. Historical requirement and test transition

FWR/FWT identify the current four-week requirements/tests. Earlier R01-R16/T00-T20 retain their meanings in frozen reports/history and legacy templates; no historical PASS transfers to a new operational test. Old quantities below are historical, not current work.

Earlier requirement	New requirement	Consolidation or retirement
R01	FWR-01	Isolation retained
R02, R03, R04	FWR-02	Capacity/admin; six zones become three
R05, R08	FWR-03	Six standard/two privileged users become three/one; twelve cases become six plus revocation
R06	FWR-04	Windows endpoint/Linux app, no extra endpoint
R07	FWR-05	Two-tier/revocation service becomes one CA/leaf, trust/expiry
R09	FWR-06	Dual pilots become one-resource Tailscale
R10	FWR-07	Six sources/twenty-event latency/retention targets become two or three sources/five events/investigation
R12	FWR-08	Two operations become one
R13	FWR-09	Enterprise objectives become measured APP1 restore
R11, R14, R15, R16	FWR-10	Hygiene, focused evidence, governance/submission/UAT retained

Earlier tests	New test	Treatment
T01, T02, T03	FWT-01; capacity also FWT-02	Isolation/readiness/conditional egress using mocks

Earlier tests	New test	Treatment
T04, T05, T06	FWT-02	Management/permits/default deny/same-zone host controls
T07, T08, T12	FWT-03	AD, six app cases and app revocation
T09	FWT-04	Endpoint baseline
T10, T11	FWT-05	Trust/name/expiry; certificate-revocation test retired
T13, T14	FWT-06	Tailscale only; Twingate retired
T15, T16	FWT-07	Time notes/five events/investigation
T18	FWT-08	One operation plus repeat/rejection
T19	FWT-09	APP1 restore, actual time/limits
T00, T17, T20	FWT-10	Publication/traceability/separate UAT

See decisions, risks and end-to-end coverage. High availability/clustering remain excluded.